

Manuscript Continuity Checkpoint

Project

The book is titled **Master of Your Domain**. It is a Springer/Apress-oriented technical monograph about Active Directory security within federal, defense, intelligence, coalition, military branches (Army, Navy, Air Force, Marine Corps, Space Force), and mission-partner environments.

The book's central thesis is:

Active Directory security in federal and military environments is not just directory administration, domain hardening, or Microsoft-product problem. Active Directory is a critical participant in a broader federal identity trust system that includes credentials, PKI, federation, cloud identity, authoritative attributes, privileged access infrastructure, mission partners, governance, recovery, restoration, and mission assurance.

The author has a full-stack perspective combining Active Directory and networking architecture, federal identity governance, offensive security, phishing and web technologies, defensive security engineering, detection, recovery, and operational mission risk.

Editorial Partnership and Writing Style

Act as the author's editorial and technical fact-checking partner. The author is a technically experienced practitioner and does not need entry-level textbook treatment.

The desired voice is:

- Operational-authoritative.
- Technically precise.
- Suitable for a Springer technical monograph.
- Confident but not sensational.
- Mission-aware without melodrama.
- Respectful of historical technologies and competing architectures.
- Prose-first rather than checklist-driven.

The most important style correction is:

Raw source material may be rough and list-heavy, but finished narrative should be continuous prose.

Use lists only when the material genuinely benefits from enumeration, such as:

- The chapter package.
- Learning objectives.
- The seven-question analytical model.
- The seven-stage identity attack lifecycle.
- Short formal comparisons.
- Selected technical inventories.
- Exercises and labs.

Do not turn the main narrative into repeated checklists of questions, tools, controls, or components. Prefer paragraphs, tables, and figures for structured material. Avoid repetitive “the defender should ask” lists.

Do not use horizontal rules in manuscript prose. Headings are acceptable when they reflect the actual chapter structure.

Book Architecture

The current working book architecture is **44 chapters in four parts**, not the previously mentioned 48-chapter structure.

Part I – Foundations and Terrain

1. Identity as the Battlefield: Why Active Directory Security Is a Federal Mission Problem
2. The Architecture of Authority: Forests, Domains, Global Catalogs, and the Shape of Trust
3. The Directory Networking Substrate: DNS, Sites, Subnets, RPC, Replication, and Domain Protocol Dependencies
4. Federal Identity Governance: FICAM, DoD ICAM, Mission Assurance, PIV/CAC, EDIPI, and Zero Trust Architecture
5. Active Directory FICAM Protocols and the Mechanics of Domain Trust: LM, NTLM, and Kerberos v5
6. Enterprise Identity Services (EIS): PKI, AD CS, AD FS, Entra ID, Federation, and Hybrid Identities
7. Policy Delivery and Directory Data: Group Policy, SYSVOL, and NTDS.dit
8. Identity Security Assessment and Baseline Engineering: Scoping, Tier 0, STIGs, SRGs, Domain Hardening, and Identity Validation

Part II – The Identity Attack Lifecycle / Offense

9. Passive Domain Identity Reconnaissance
10. Active Directory Domain Enumeration and Graph Pathing

11. AD CS Certificate Template and FPKI Enumeration
12. Password Spraying, Credential Stuffing, and Lockout-Aware Brute-Force
13. Domain Name Resolution Poisoning
14. Authentication Coercion and Relay
15. Phishing, MFA Fatigue, OAuth Consent, and Cloud/Hybrid Footholds
16. AS-REP Roasting and Kerberoasting
17. LSASS, SAM, GPP, cpassword, and Cached Credential Extraction
18. Pass-the-Hash, Overpass-the-Hash, and Pass-the-Ticket Session Replay
19. Cloud Tokens and Certificate/Key Theft
20. ACL/DACL/ACE Abuse
21. AD CS Domain Enumeration
22. Entra ID Administrative Role Abuse and Hybrid Escalation
23. Remote-Service Movement
24. Cross-Domain and Cross-Forest Traversal
25. Domain Dominance and Network Persistence

Part III – Defense: Engineering, Detection, and Recovery

26. Domain Tiered Administration and ESAE / Red Forest
27. End-User Isolation
28. Domain Service Account and gMSA Hardening
29. AD CS/PKI Hardening
30. AD FS and Federation Hardening
31. Name Resolution and Relay Hardening
32. Detection Engineering
33. Detecting Replication Abuse and Lateral Movement
34. Threat Hunting the Directory
35. Deception with Honeytokens
36. Identity Forensics
37. Incident Response Playbooks and SOAR Containment
38. KRBTGT Double-Reset and Kerberos Trust Rotation
39. Tier 0 Forest Recovery, AD CS Recovery, and Federation Trust Repair
40. Hybrid and Entra ID Defense

Part IV - Closing

41. Operational Lessons and the Future of Identity-Centric Defense and Warfare

Book-Level Structural Decision

The source material revealed that two different chapters had been conflated:

1. A governance chapter about FICAM, federal authorities, identity lifecycle, assurance, and Zero Trust.
2. A technical architecture about forests, domains, trusts, schema, OUs, replication, Global Catalogs, and domain controllers.

The decision is final:

Chapter 2 is the technical architecture chapter: The FICAM governance material is promoted to Chapter 4.

The intended progression is:

Mission stakes → authority structure → networking substrate → federal identity governance → protocols and trust → enterprise identity services

Do not force governance material into Chapter 2 simply because an earlier draft labeled it “Chapter 2.”

Chapter 1 Status

Chapter 1 is structurally complete but not yet prose-final.

Chapter 1 Title

Identity as the Battlefield: Why Active Directory Security Is a Federal Mission Problem

Chapter 1 Core Framework

The chapter establishes:

- The Identity Trust System as the principal analytical unit.
- Active Directory as more than a directory service.
- The distinction between domain, forest, and broader identity trust system.
- FICAM versus DoD ICAM.
- Person Entities and Non-Person Entities.
- Identity proofing, credential issuance, and credential binding.
- IAL, AAL, FAL, and legacy LOA terminology.
- Identity as contested terrain.
- Attacker-oriented reasoning as a defensive discipline.
- Assume Breach as an engineering model.
- The Active Directory Identity Attack Lifecycle.
- The defender’s visibility problem.
- Federal mission risk and the identity control plane.
- Governance, authorization, evidence, recovery, and trust restoration.

- The Seven-Question Analytical Method.
- The four-part progression of the book.

Chapter 1 Major Editorial Decisions

- Historical material on Novell, NDS/eDirectory, Windows NT, and Active Directory remains, but must be compressed.
- Trust-extension material should not be repeated across multiple sections.
- Protocol mechanics should primarily move to Chapters 3 and 5.
- The duplicated Users, Computers, Groups, and Services material should become one consolidated treatment.
- The former Sections 1.11 and 1.12 may be merged conceptually into a book-approach and reader-contract section, subject to final numbering.
- Offensive tools should be introduced conceptually only in Chapter 1; operational tool instruction belongs in later chapters.
- The chapter package should not be confused with numbered narrative sections.
- Chapter 1 must not claim the book has 48 chapters.

Chapter 1 EDIPI Correction

The author supplied an important revision to the EDIPI passage. Preserve the following conceptual content:

The Electronic Data Interchange Personal Identifier (EDIPI) illustrates both the value and the limit of identity data. Commonly known as the DoD Identification Number, the EDIPI is a unique ten-digit personal identifier created for and assigned to a person entity with a direct relationship to the Department of Defense. It is intended to replace the Social Security Number (SSSN) for many DoD business purposes, and an assigned EDIPI is not resued for any other individual once assigned to a person entity.

The Department of Defense stores the EDIPI in the Defense Enrollment Eligibility Reporting System (DEERS), a centralized identity and eligibility database maintained within the Defense Manpower Data Center (DMDC) environment. DEERS supports identity, personnel, eligibility, and affiliation records for populations including active-duty service members, reservists, civilian employees, contractors, dependents, and other eligible beneficiaries. The Real-time Automated Personnel Identification System (RAPIDS) uses DEERS data during identity-card issuance. For eligible cardholders, RAPIDS supports issuance of a Common Access Card (CAC), on which the DoD identification number is represented through the cards printed and electronic identity data.

The EDIPI is not an authenticator. Possession or knowledge of the identifier neither authenticates nor authorizes; its security value depends entirely on correct binding to the correct identity record and accurate propagation across the systems that consume it. An EDIPI that is correctly bound and consistently synchronized is a governance asset. An EDIPI that drifts across records, is bound to the wrong person entity, or is treated as if knowing it proved identity becomes a liability.

Use careful language around DEERS, DMDC, RAPIDS, CAC eligibility, and dependents. Do not imply that every person in DEERS receives a CAC.

LOA Decision

LOA 1-4 was accidentally omitted from the earlier treatment. The decision is:

- Mention legacy LOA 1-4 briefly in Chapter 1§1.3.6.
- Treat IAL, AAL, and FAL as the current analytical model.
- Explain that LOA was an earlier combined federal assurance model.
- Explain that LOA remains relevant for historical requirements, inherited authorization packages, and legacy PIV/CAC documentation.
- Give the full LOA-to-current-model treatment in Chapter 4.
- Do not present LOA as a fifth current assurance dimension.

The conceptual distinction is:

- IAL; identity-proofing confidence.
- AAL: authentication confidence.
- FAL: federation/assertion protection.
- Legacy LOA: an earlier combined assurance model.
- Authorization: a separate decision that none of these levels independently grants.

Chapter 1 Prose Status

The initial drafts of Sections 1.4 and 1.5 were too list-heavy. The author explicitly objected to the checklist-driven style. They were not yet fully rewritten when work shifted to Chapter 2.

Before Chapter 1 is considered prose-final:

- Rewrite 1.4 in continuous prose.
- Rewrite 1.5 in continuous prose.
- Preserve the analytical content but eliminate repetitive inventories.
- Keep only genuinely useful enumerations.

- Harmonize terminology and cross-references after the renaming Chapter 1 sections are drafted.

Chapter 2 Authoritative Source

The latest authoritative Chapter 2 sources is **Version 3**, titled:

The Architecture of Authority: Forests, Domains, Trusts, and the Shape of Trust

This replaces the governance-focus drafts as the Chapter 2 source.

Chapter 2 Thesis

Active Directory architecture is a map of authority, dependency, and trust – not an inventory of objects.

The chapter explains what each architectural component is, what authority or dependency it creates, and what security boundary it does or does not provide. It does not teach exploitation or detailed networking mechanics.

Chapter 2 Current Narrative Structure

- 2.1 Reading Architecture as a Map of Authority
- 2.2 The Forest: The Highest Conventional AD DS Security Boundary
- 2.3 Domains and Trees: Administrative Structure Within the Forest
- 2.4 The Schema: Forest-Wide and Durable
- 2.5 Organizational Units: Delegation and Policy Scope
- 2.6 Trusts: The Shape of Interoperability
- 2.7 Sites and Domain Replication: The Movement of Directory Authority
- 2.8 Global Catalog Servers: Forest-Wide Directory Visibility
- 2.9 Domain Controllers: Authoritative Identity Infrastructure
- 2.10 Summary and Transition

Chapter 2 Sections Already Drafted

The following sections have been drafted in prose-first form:

- 2.1 Reading Architecture as a Map of Authority
- 2.2 The Forest: The Highest Conventional AD DS Security Boundary
- 2.3 Domains and Trees: Administrative Structure Within the Forest
- 2.4 The Schema: Forest-Wide and Durable
- 2.5 Organizational Units: Delegation and Policy Scope
- 2.6 Trusts: The Shape of Interoperability

- 2.7 Sites and Domain Replication: The Movement of Directory Authority

The next section to draft is:

2.8 Global Catalog Servers: Forest-Wide Directory Visibility

After that, draft 2.9 Domain Controllers and 2.10 Summary and Transition

Chapter 2 Technical Corrections to Preserve

A domain should be described as an authentication, naming, policy, administrative, and domain-directory replication scope. Do not imply that everything associated with the domain stops at its boundary.

The forest is the highest conventional AD DS security boundary but avoid absolute claims such as “forest compromise automatically means everything is compromised.” State the forest-level authority creates the potential to affect every domain within the forest, while actual consequences depend on authority obtained and implemented control pathways.

Distinguish AD DS trusts from federation relationships. They may solve related interoperability problems but use different mechanisms and impose different responsibilities.

A domain controller, through its Kerberos KDC, issues Kerberos tickets. Federation and cloud systems may issue other types of tokens or assertions while consuming directory information. Do not collapse all of these into “domain controllers issue tokens.”

A Global Catalog server holds:

- A full replica of its own domain’s directory partition.
- A partial attribute set for objects in other domains in the forest.

Do not describe it as holding a complete copy of the entire forest.

Organizational Units are delegation and policy scopes, not security boundaries.

Sites model network connectivity and service location. Chapter 3 will cover DNS, subnets, RPC, site links, replication mechanics, scheduling, latency, convergence, and troubleshooting.

Chapter 2 Style Rule

Use the recurring prose pattern:

Architectural function → authority or dependency → security significance → boundary limitation → transition.

Avoid “Did You Know?” labels. Convert useful sidebar points into normal prose or occasional formal “Architectural Note” callouts only if needed.

The chapter should not become a protocol chapter, attack chapter, or governance chapter.

Chapter 2 Source Audit Outcome

The chapter’s strongest ideas are:

- The forest is a shared authority environment, not merely a container.
- Domains are meaningful operational scopes but not guaranteed isolation from forest-level authority.
- Trees describe contiguous namespaces and parent-child trust relationships.
- Schema is forest-wide, durable, and foundational.
- OUs express intended administration and policy scope but do not wall objects off from broader authority.
- Trusts are configurable interoperability paths, not binary on/off relationships.
- Trust direction, transitivity, authentication scope, filtering, name-suffix behavior, resource authorization, and administration determine trust posture.
- Sites and replication distribute identity data and authority.
- Global Catalog servers concentrate partial forest-wide visibility.
- Domain controllers are authoritative Tier 0 identity infrastructure.
- Architecture must be read relationally: who can affect what, what depends on what, and how changes propagate.

Governance Material Disposition

The governance-focused Chapter 2 material is not discarded. It is promoted to Chapter 4.

Potential Chapter 4 structure:

1. Governance Before Technology.
2. The Evolution of Federal Identity Management.
3. FICAM, Federal ICAM, and DoD ICAM.
4. HSPD-12, FIPS 201, PIV, CAC, and Derived Credentials.

5. Identity Proofing, Credential Issuance, and Lifecycle Management.
6. IAL, AAL, FAL, and Legacy LOA 1–4.
7. Authentication, Authorization, Federation, and Trust Relationships.
8. RBAC, ABAC, and Privileged Access.
9. Person Entities, Non-Person Entities, and Identity Ownership.
10. Zero Trust Architecture and Identity-Centric Security.
11. FICAM Across Civilian, Defense, Combatant Command, and Mission-Partner Environments.
12. From Governance Decision to Technical Control.
13. Chapter Summary and Transition.

The governance draft's strongest opening is **"Governance Before Technology."** Its central argument is that technology enforces decisions made elsewhere:

- AD DS can store an account but cannot decide whether the person still requires access.
- PKI can issue a certificate but cannot establish mission justification.
- Federation can transmit an assertion but cannot independently decide whether the issuer should be trusted for a transaction.
- Entra ID can enforce policy but cannot independently determine whether attributes, roles, devices, and exceptions reflect current mission requirements.

The governance draft should be revised into prose-first style when Chapter 4 is developed.

Move or limit the following:

- FedRAMP and cloud identity governance: Chapter 4, Chapter 6, and Chapter 42.
- Detailed RMF, eMASS, POA&M, ConMon, and OSCAL: primarily Chapter 43.
- BloodHound, PowerView, Certipy, and PingCastle operational treatment: Chapters 10, 11, 22, 8, and 36.
- USCYBERCOM, JFHQ-DoDIN, CORA, and organizational surveys: include selectively in Chapter 4 only where they clarify mission governance.

- CMMC and DIB content: include only if it remains relevant to the identity-governance argument; do not let it overwhelm Chapter 4.

Important Terminology and Conceptual Rules

Use these distinctions consistently:

- Domain ≠ forest.
- Forest ≠ broader identity trust system.
- OU ≠ security boundary.
- Authentication ≠ authorization.
- Identity proofing ≠ authentication.
- Credential issuance ≠ credential binding.
- Identity recognition ≠ access authorization.
- Technical validity ≠ operational legitimacy.
- Access pathway ≠ control pathway.
- Service restoration ≠ trust restoration.
- Administrative ownership ≠ effective control.
- Current assurance model: IAL/AAL/FAL.
- Legacy assurance model: LOA 1–4.
- FICAM ≠ Microsoft product.
- DoD ICAM ≠ an edition of Active Directory.
- AD DS ≠ Entra ID, although bridges may connect them.
- AD trust ≠ federation.
- Domain controller ≠ generic server.
- NPE identity ≠ unmanaged technical exception.
- Tier 0 is defined by effective control, not only by product labels or group membership.

Seven-Question Analytical Method

This method structures the rest of the book:

1. What identity or trust function is being performed?
2. What systems, protocols, permissions, credentials, attributes, or relationships expose that function?
3. How can the function be abused, bypassed, manipulated, or subverted?
4. What evidence, logs, directory changes, protocol behavior, or anomalies reveal the activity?
5. How should defenders contain the attack and remediate the enabling condition?
6. How can the agency validate that the corrected control resists the same pathway?
7. Which governance, assurance, authorization, recovery, and mission requirements are affected?

Use this as an analytical structure, not as a repeated checklist in every paragraph.

Active Directory Identity Attack Lifecycle

The book uses a seven-stage analytical model:

1. Passive Identity Reconnaissance.
2. Initial Identity Acquisition.
3. Active Internal Discovery and Enumeration.
4. Credential Acquisition.
5. Identity Authority Expansion.
6. Enterprise Identity Mobility.
7. Persistence and Domain Dominance.

The lifecycle is not a rigid sequence. Intrusions may skip, repeat, combine, or reverse stages.

Manuscript Workflow

The author is building an HTML “Book Architect” dashboard because a large Word document became too slow and unstable.

The HTML page should serve as a live structural dashboard, not necessarily the full manuscript. Recommended metadata includes:

- Part.

- Chapter.
- Section hierarchy.
- Structure status.
- Source-material status.
- Prose status.
- Technical-review status.
- Editorial status.
- Thesis.
- Open questions.
- Dependencies.
- Figures.
- Tables.
- Case studies.
- Exercises.
- References.
- Change log.

The current HTML prototype contains sample fiction data and should eventually be replaced with the actual 44-chapter structure. Important implementation improvements previously identified:

- Add `localStorage` persistence.
- Export/import JSON.
- Fix duplicate right-panel rendering.
- Avoid double-counting chapter and section word counts.
- Add deeper hierarchy if needed.
- Separate structure status from prose, technical, and editorial status.
- Replace fiction tags with manuscript tags.

- Track real last-edited timestamps.
- Add notes, open questions, dependencies, and change history.

Do not require the author to polish raw material before sending it. The author may continue sending attachments, rough notes, or parsed PDFs. Perform the structural, technical, and prose surgery afterward.

Immediate Next Action

Continue Chapter 2 with:

2.8 Global Catalog Servers: Forest-Wide Directory Visibility

Focus on:

- What a Global Catalog server is.
- Full local-domain replica versus partial attribute set for other domains.
- Cross-domain lookups and selected logon-related operations.
- Forest-wide visibility as a security-relevant property.
- The distinction between visibility and administrative authority.
- Why Global Catalog placement, protection, monitoring, and recovery matter.
- Avoiding enumeration techniques, which belong in Chapter 10.
- Transition to domain controllers as authoritative identity infrastructure.

Then draft:

2.9 Domain Controllers: Authoritative Identity Infrastructure

Focus on:

- Domain controllers as Tier 0 authority nodes.
- Authentication and Kerberos services.
- Directory storage and replication.
- Privileged access and administrative logons.
- Network reachability and protection.
- Backup, virtualization, monitoring, and recovery dependencies.
- Why a domain controller is not an ordinary server.

Finally draft:

2.10 Summary and Transition

Transition to Chapter 3:

The next chapter turns from the logical structure of authority to the networking substrate that allows directory services to be located, communicated, replicated, and enforced.

When continuing, preserve the prose-first Springer style and do not re-open settled structural decisions unless new source material demonstrates a genuine architectural problem